

One-Pager: Building a Realistic Clean-vs-Malicious URL Dataset

Goal

Train/evaluate models on **hard** negatives and realistic positives so the classifier doesn't learn trivial shortcuts (e.g., "short $\Rightarrow$ benign, long $\Rightarrow$ malicious").

Data Sources (links)

Malicious (positives)

- URLhaus (malware delivery) – API & CSV dumps with timestamps/tags: <https://urlhaus.abuse.ch/api/> and https://urlhaus.abuse.ch/downloads/csv_recent/ and https://urlhaus.abuse.ch/downloads/csv_online/
- OpenPhish (phishing) – community/commercial feeds: <https://openphish.com/> and https://openphish.com/phishing_feeds.html
- PhishTank (phishing) – open API (check limits): https://dev.phishtank.com/developer_info.php and https://phishtank.net/api_info.php
- PhishStats (phishing) – search & API: <https://phishstats.info/> (API: <https://api.phishstats.com/>)

Benign (hard negatives)

- Tranco top domains (research-grade, less gameable than Alexa): <https://tranco-list.eu/> (paper: <https://www.ndss-symposium.org/ndss-paper/tranco-a-research-oriented-top-sites-ranking-hardened-against-manipulation/>)
- Common Crawl (WARC/WAT + indices) – mine **deep, long, param-heavy** benign URLs:
 - CC Index (Athena how-to): <https://github.com/commoncrawl/cc-index-table> and <https://commoncrawl.org/blog/index-to-warc-files-and-urls-in-columnar-format>
 - CDX Index API: <https://index.commoncrawl.org/> (client: <https://github.com/ikreymer/cdx-index-client>)

DGA/AGD (robustness / auxiliary eval)

- DGArchive (Fraunhofer FKIE) – large DGA corpus: <https://dgarchive.caad.fkie.fraunhofer.de/>

Academic baseline

- ISCX/CIC-URL2016 dataset: <https://www.unb.ca/cic/datasets/url-2016.html>

Build Process (do this)

1. Collect & dedupe positives

- Pull URLhaus (malware) and phishing feeds (OpenPhish, PhishTank, PhishStats).
- Keep `first_seen` dates and `tags/brand` (where available).
- Normalize + **dedupe** by: full URL hash; normalized URL (lowercase host, sorted params); and *eTLD+1 + path*.

2. Mine hard benigns

- Start from **Tranco** top N domains (e.g., 100k).
- Use **Common Crawl** to sample URLs from those domains with filters such as:
 - `length(url) ≥ 100`, `path depth ≥ 4`, `parameters ≥ 3`,
 - contains percent-encoding (e.g., `%2F`, `%3D`),
 - long query tokens (`≥ 16` chars), `digit ratio ≥ 0.3`,
 - hex/base64-ish chunks, tracking params (`utm_`, `gclid`, `fbclid`).
- Keep HTTP(S) pages only if you later parse WAT/headers (optional).

3. Balance & match distributions

- Match **host popularity (Tranco rank bands)**, TLD mix, average length, subdomain depth, presence of shorteners (t.co/bit.ly) across benign vs malicious.

4. Splits to avoid leakage

- **Time-based split** using `first_seen`: train on dates **before** cutoff; test **after**.
- **Domain holdout**: no eTLD+1 overlap between train/test.
- (Optional) **Campaign/brand holdout** using feed tags or brand fields.

5. Label hygiene

- Treat feeds as weak labels; reconcile conflicts; drop contradictions. If you ever crawl, mark "alive/dead" (for analysis only).

6. Baselines (URL text only)

- **Char-level model** (1D-CNN or small Transformer) on raw URL.
- **Feature GBM** with lexical features: length/entropy/digit ratio, path depth, %-encoding runs, IP-in-host, edit-distance to brand names, TLD flags.
- Calibrate probabilities; evaluate with **PR-AUC** and **ROC-AUC** on time+domain held-out test.

7. When to add metadata (next step)

- If URL-only stalls: add **DNS/WHOIS/TLS** (domain age, registrar, ASN, cert issuer/validity) and later sandboxed HTTP headers or HTML title.

Common Crawl: quick recipe (for long/deep benign URLs)

Athena (CC-Index)

- Create `ccindex` DB/table (see: <https://github.com/commoncrawl/cc-index-table>):
 - Filter examples: `length(url) >= 100`, `url LIKE '%?%'`, `REGEXP_LIKE(url, '(%[0-9A-Fa-f]{2}){2,})'`, `regexp_like(url, '(:?/[^\/*]{4,})'`.
 - Restrict to Tranco domains: join against your Tranco list.

CDX API (simpler)

- Query `https://index.commoncrawl.org/` collections for each Tranco domain; filter client-side by length/depth/params.
-

Things to watch out for

- **Licenses/ToS** (e.g., OpenPhish community feed restrictions for commercial use).
 - **Feed bias** (don't become an "OpenPhish detector": mix multiple phishing sources).
 - **Shortcut features** (e.g., only using top-homepage benigns). Always **hard-negative mine** from Common Crawl and match distributions.
-

Minimal Starter Packs

- **Malware delivery**: URLhaus (positives) vs Tranco-seeded, CC-mined long/deep URLs (negatives). Time + domain holdout.
- **Phishing**: OpenPhish + PhishTank + PhishStats (positives) vs same CC/Tranco negatives.